bakery-example.com

Audit de sécurité passif par Loïc Tellier · 17/10/2026 · note globale = domaine le plus faible

Exposition élevée : des corrections prioritaires sont nécessaires.

Global	Site web	Certificat & TLS	Email	Domaine & DNS
F	**F**	**A**	**C**	**B**
domaine le plus faible	15/100 · barème Mozilla HTTP Observatory	90/100 · barème du projet (RFC 8996, validité du certificat)	55/100 · barème du projet (RFC 7208, 7489, 6376, 8461)	75/100 · barème du projet (RFC 4033, 8659)

0 critique · 12 à améliorer · 4 conforme · 11 info

Actions prioritaires

1. **Content-Security-Policy** (À améliorer)
   Définissez une CSP adaptée au site, en commençant en mode « Report-Only ».
2. **Redirection HTTP vers HTTPS** (À améliorer)
   Mettez en place une redirection permanente (301) de HTTP vers HTTPS.
3. **HSTS** (À améliorer)
   Ajoutez « Strict-Transport-Security: max-age=31536000; includeSubDomains ».
4. **Protection contre le clickjacking** (À améliorer)
   Ajoutez « X-Frame-Options: SAMEORIGIN » ou « frame-ancestors 'self' » dans la CSP.
5. **SPF (expéditeurs autorisés)** (À améliorer)
   Passez à « ~all », puis à « -all » une fois vos expéditeurs listés.
6. **DMARC (politique anti-usurpation)** (À améliorer)
   Après quelques semaines d'analyse des rapports, passez à « quarantine », puis à « reject ».
7. **DNSSEC** (À améliorer)
   Activez DNSSEC chez votre hébergeur DNS, puis publiez l'enregistrement DS chez votre registrar (souvent une simple option dans son interface).
8. **Certificat HTTPS** (À améliorer)
   Vérifiez que le renouvellement automatique est en place.
9. **MTA-STS (livraison chiffrée des emails)** (À améliorer)
   Publiez une politique MTA-STS (d'abord en mode « testing »), ou activez-la dans votre service de messagerie.
10. **CAA (autorités de certification autorisées)** (À améliorer)
    Publiez un enregistrement CAA qui nomme l'autorité que vous utilisez, par exemple 0 issue "letsencrypt.org".
11. **Verrou de transfert** (À améliorer)
    Activez le verrou de transfert (souvent appelé « registrar lock ») chez votre registrar.
12. **Versions des logiciels affichées** (À améliorer)
    Masquez les numéros de version dans la configuration du serveur.

Sécurité du site web

À améliorer	**Content-Security-Policy** Absent : aucune limite sur les scripts que la page peut charger (protection contre les injections XSS). > Définissez une CSP adaptée au site, en commençant en mode « Report-Only ». Source : W3C Content Security Policy niveau 3 — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R14, R15, R16	-25 pts
À améliorer	**Redirection HTTP vers HTTPS** Le site reste accessible en HTTP non chiffré, sans redirection. > Mettez en place une redirection permanente (301) de HTTP vers HTTPS. Source : Guide TLS de MDN : redirection HTTP — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R1	-20 pts
À améliorer	**HSTS** Absent : le navigateur n'est pas obligé d'utiliser HTTPS lors des visites suivantes. > Ajoutez « Strict-Transport-Security: max-age=31536000; includeSubDomains ». Source : RFC 6797 (HTTP Strict Transport Security) — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R2	-20 pts
À améliorer	**Protection contre le clickjacking** Le site peut être affiché dans un cadre sur un autre site (risque de clickjacking). > Ajoutez « X-Frame-Options: SAMEORIGIN » ou « frame-ancestors 'self' » dans la CSP. Source : RFC 7034 (X-Frame-Options) — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R17, R18	-20 pts
À améliorer	**Versions des logiciels affichées** Le serveur annonce ses versions (Server: Apache/2.4.41 (Ubuntu); X-Powered-By: PHP/7.4.3), ce qui aide un attaquant à cibler des failles connues. > Masquez les numéros de version dans la configuration du serveur. Source : OWASP Secure Headers Project	non noté
Info	**Cookies** Aucun cookie déposé sur la page d'accueil. Source : RFC 6265 (cookies HTTP) et guide MDN sur les cookies — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), §5.5.3	0 pts
Info	**Referrer-Policy** Absent : les navigateurs appliquent leur politique par défaut (strict-origin-when-cross-origin dans les versions récentes). > Ajoutez « Referrer-Policy: strict-origin-when-cross-origin » (rapporte des points bonus). Source : W3C Referrer Policy — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), §5.4	0 pts
Info	**Subresource Integrity (intégrité des scripts)** Aucun script sur la page d'accueil. Source : W3C Subresource Integrity — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R11, R12	0 pts

Info	**Cross-Origin-Resource-Policy** Non défini (facultatif ; rapporte des points bonus s'il est défini). Source : MDN : Cross-Origin-Resource-Policy	0 pts
Info	**Cross-Origin-Opener-Policy** Non défini (facultatif ; rapporte des points bonus s'il est défini). Source : MDN : Cross-Origin-Opener-Policy	0 pts
Info	**Cross-Origin-Embedder-Policy** Non défini (facultatif ; rapporte des points bonus s'il est défini). Source : MDN : Cross-Origin-Embedder-Policy	0 pts
Info	**Permissions-Policy** Absent : aucune restriction d'accès aux fonctions du navigateur (caméra, micro, géolocalisation). > Ajoutez par exemple « Permissions-Policy: camera=(), microphone=(), geolocation=() ». Source : W3C Permissions Policy	non noté
Info	**security.txt (signalement de failles)** Aucun fichier security.txt : une personne qui trouve une faille sur le site ne sait pas qui prévenir. > Publiez /.well-known/security.txt avec au moins un champ Contact et un champ Expires (par exemple généré sur securitytxt.org). Source : RFC 9116 (security.txt)	non noté
Conforme	**X-Content-Type-Options** Présent (nosniff). Source : WHATWG Fetch : X-Content-Type-Options — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R6	0 pts

Certificat & TLS

À améliorer	**Certificat HTTPS** Le certificat expire dans 20 jours (07/11/2026). > Vérifiez que le renouvellement automatique est en place. Source : Guide TLS de MDN — Voir aussi : Guide ANSSI TLS v1.2 (2020), R8	-10 pts
Conforme	**Version du protocole TLS** Connexion établie en TLSv1.3. Source : RFC 8996 (abandon de TLS 1.0 et 1.1) — Voir aussi : Guide ANSSI TLS v1.2 (2020), R3, R4 · Guide ANSSI site web PA-009 v2.0 (2021), R1	0 pts

Protection des emails

À améliorer	**SPF (expéditeurs autorisés)** L'enregistrement SPF se termine par « ?all » (neutre) : il ne protège presque pas. > Passez à « ~all », puis à « -all » une fois vos expéditeurs listés. Source : RFC 7208 (SPF) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), R44	-20 pts
À améliorer	**DMARC (politique anti-usurpation)** Politique « none » : DMARC observe mais ne bloque rien. > Après quelques semaines d'analyse des rapports, passez à « quarantine », puis à « reject ». Source : RFC 7489 (DMARC) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), R48+	-20 pts
À améliorer	**MTA-STS (livraison chiffrée des emails)** Non défini : les autres serveurs de mail peuvent vous livrer vos emails sans chiffrement si un attaquant perturbe la connexion. > Publiez une politique MTA-STS (d'abord en mode « testing »), ou activez-la dans votre service de messagerie. Source : RFC 8461 (SMTP MTA Strict Transport Security) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), §5.3	-5 pts
Info	**DMARC : rapports** Aucune adresse de rapport (rua) : vous ne voyez pas qui envoie des emails en votre nom. > Ajoutez « rua=mailto:... » pour recevoir les rapports agrégés. Source : RFC 7489 (DMARC) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), R48+	0 pts
Info	**DKIM (signature des emails)** Aucune clé DKIM trouvée parmi les sélecteurs courants testés (16). Ce n'est pas forcément un problème : le sélecteur peut avoir un autre nom. > Vérifiez dans votre service de messagerie (Google Workspace, Microsoft 365...) que la signature DKIM est activée. Source : RFC 6376 (DKIM) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), R46+	non noté
Info	**Rapports TLS (TLS-RPT)** Non défini : vous n'êtes pas prévenu quand d'autres serveurs n'arrivent pas à vous livrer vos emails de façon sûre. > Publiez un enregistrement TXT _smtp._tls, par exemple « v=TLSRPTv1; rua=mailto:tls-reports@votre-domaine ». Source : RFC 8460 (rapports TLS pour SMTP) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), §5.3	non noté
Conforme	**Serveurs de mail (MX)** 2 serveur(s) : mx1.hosting-example.com, mx2.hosting-example.com Source : RFC 7505 (MX nul pour les domaines qui ne reçoivent pas d'email)	0 pts

Domaine & DNS

À améliorer	**DNSSEC** Non activé pour bakery-example.com : les réponses DNS ne sont pas signées, un résolveur ne peut donc pas détecter de fausses réponses (qui redirigeraient visiteurs ou emails vers un autre serveur). > Activez DNSSEC chez votre hébergeur DNS, puis publiez l'enregistrement DS chez votre registrar (souvent une simple option dans son interface). Source : RFC 4033 (introduction et exigences de la sécurité DNS) — Voir aussi : Guide ANSSI noms de domaine BP-038 v1.3 (2017), R4+ · Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), R50+	-15 pts
À améliorer	**CAA (autorités de certification autorisées)** Aucun enregistrement CAA : n'importe quelle autorité de certification peut émettre un certificat pour ce domaine. > Publiez un enregistrement CAA qui nomme l'autorité que vous utilisez, par exemple 0 issue "letsencrypt.org". Source : RFC 8659 (autorisation des autorités de certification par DNS)	-5 pts
À améliorer	**Verrou de transfert** Le domaine n'est pas verrouillé contre les transferts : avec un accès volé à votre compte chez le registrar, il est plus facile de le déplacer ailleurs. > Activez le verrou de transfert (souvent appelé « registrar lock ») chez votre registrar. Source : RFC 5731 (statuts d'un domaine, dont l'interdiction de transfert) — Voir aussi : Guide ANSSI noms de domaine BP-038 v1.3 (2017), R1, R3+	-5 pts
Conforme	**Date d'expiration du domaine** Le domaine bakery-example.com est enregistré jusqu'au 05/05/2027 (199 jours). Registrar : Example Registrar. Source : RFC 9083 (RDAP, données d'enregistrement des noms de domaine) — Voir aussi : Guide ANSSI noms de domaine BP-038 v1.3 (2017), §4.10	0 pts

Méthode. Audit passif réalisé par Loïc Tellier à partir d'informations publiques uniquement : enregistrements DNS, certificat présenté par le serveur et page d'accueil. Aucun test d'intrusion n'a été effectué. Notes. La note du site web suit le barème Mozilla HTTP Observatory (pénalités et bonus par en-tête). Les notes certificat, email et DNS suivent le barème propre au projet, fondé sur les normes citées sous chaque point. La note globale est la plus basse des quatre. Limites. Cet audit ne couvre pas les applications du site, les postes de travail ni les comptes utilisateurs. Il donne une vue d'ensemble de l'exposition visible depuis Internet à la date indiquée. Les recommandations de l'ANSSI citées indiquent à quoi se rattache chaque contrôle ; les respecter pleinement dépend aussi de réglages invisibles depuis l'extérieur : ce rapport n'est donc pas une attestation de conformité.